Malicious Software & Denial of service attack

Introduction to Malicious Software

What is Malware?
- program inserted into a system, usually covertly, with the
  - intent of compromising CIA of victims data
  - unwanted software that does something bad

Attack sources
- politically motivated attackers
- criminals
- organized crime
- national government agencies

Attack kits
- kits used to create the malware
- often known as "crimeware"

Classification of malware
- two broad categories
  - how it spreads (virus, worms, social engineering)
  - actions/payloads it performs (system corruption, zombies, bots, info theft, stealthing)
- also classified by
  - those who need a host program (viruses)
  - independent, self-contained program (worms, trojan, bots)
  - malware that does not replicate (trojan, spam email)
  - malware that replicates (virus, worms)
    - spreads via host
    - self replicating, can consume system/network bandwidth
- countermeasures
  - antivirus software

Malware Symptoms
- unexpected behavior
- contacts receive emails you didnt send
- GUI changes
- slow boots & login
- browser goes to wrong page

Viruses

What is a virus?
- piece of software that infects programs
- when attached to exe program, virus can do anything program is
  - permitted to do
  - specific to OS & Hardware

Nature of viruses
- "infects" programs & copies itself to other programs
- phases
  - dormant: virus is idle, will be activated by agent (logic bomb)
  - propagation: copies itself
  - triggering: virus activated
  - execution: function performed, either harmless or malicious

Compression virus (CV)
- simple virus can be detected cause it changes file length
- this detection is avoided with this virus
  - for each uninfected file P2, virus compresses P2 to produce P2'
  - virus CV pre-pended to P2'
  - P1 is then uncompressed

Virus Classifications
- by target
  - boot sector infector
  - file infector
  - macro virus
  - multipartite virus
- by concealment strategy
  - encrypted virus
  - stealth virus
  - polymorphic virus
  - metamorphic virus

Macro-virus
- attaches to documents & uses macro programming capabilities of the
  - document application to execute & propagate (Melissa)
  - platform independent
- spreads easily
- much easier to write

Worms & Social Engineering

What are worms?
- seeks more machines to infect
  - spreads through shared media
- exploit software
  - spread in macro/script codes
- can use network to spread
  - usually carries payload

Examples
- code Red targeted microsoft web servers, stored in RAM, consumed network (DoS attack)
- code Red II similar to above, installed trojan horse, delete/modify files on server
- Stuxnet targets PLC/SCADA, damaged Iran nuclear program

Worm Target Discovery
- scanning searches for systems to infect
- random probes random addresses
- hit-list attacker compiles potential vulnerable machines
- topological infected machine finds more hosts
- local subnet looks for more targets in local network

Social engineering
- master of asking non-invasive info to gather info over time
- gain trust, reduce defenses
- phishing, spear phishing, whaling
  - attack via email, website, call
  - targeted attack from trusted source & more personalized for each person
  - target high profile people

Case study
- fake Jeff Bezos profile asked to send bitcoin & he will double

Other malwares & Countermeasures

Other types of Malware
- ransomware encrypts system files, then asks money (crypto)
- rootkit infects BIOS, hard to detect

Zombies & Bots
- botnet of zombies "botnet" = "robot network" "zombie" computer under external control
  - DDoS, spamming, sniff trafic, keylogging

Information Theft
- keyloggers mainly logs login, password keywords
- spyware redirects to fake websites, monitors browsing

System Corruptions
- action taken by malware on system
- data destruction delete data, encrypt data then ask payment
- damage corrupt BIOS, control SCADA
- logic bomb activate when condition is met

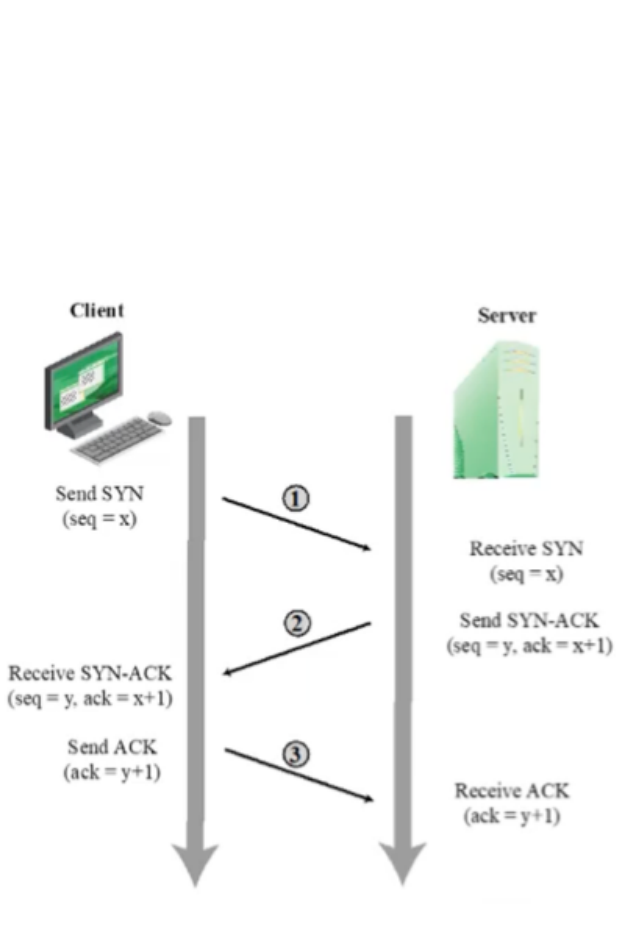
Counter measures
- prevention is ideal, often impossible access control, ensure up to date
- detection, identification, removal antivirus

Introduction to Denial-of-Service (DoS)

What is DoS attack?
- action that prevents authorized use of networks, systems, appliances
  - by exhausting resources such as CPU, memory, bandwidth & disk space
  - categories that could be attacked
    - network bandwidth
    - application resources
    - system resources

Flooding Attacks
- classified based on nw protocol used
  - ICMP flood ping flood
  - UDP flood UDP packets
  - TCP/SYN flood TCP packets

Classic DoS (TCP SYN Flood)
- Transmission Control Protocol
  - works with internet protocol
  - 3 way handshake
  - Attacker sends SYN but no ACK
- Countermeasure
  - difficult, filter packets at routers
  - SYN cookies



ICMP DoS Attack

Ping Test
- most computers respond
- error-reporting /check delay

Simple Ping Flooding Attack
- attacker has high capacity link
- target's connection to internet is lower capacity
  - assumptions
- flood the server
- countermeasure
  - ISPs block ping (ICMP) packets
  - target identifies source, inform ISP, take legal action
  - ICMP response sent back to attacker, affect their performance

Source Address Spoofing
- attacker sends packets with fake (spoofed) source IP
  - target does not (immediately) know who it is
  - responses not sent to attacker
  - source may be actual host or non-existent
- can use Network Address Translation (NAT) to spoof IP

Distributed DoS

What is DDoS?
- use of multiple systems
- use flaw in OS or common application to gain access & install
  - program on it (zombie)
  - lot of zombies create botnet

Reflector Attack
- bounce msgs off normal hosts
- all hosts respond to target because attacker uses spoofed source IP
  - of target and sends to other computers
  - response larger than request

Amplification Attack using Broadcast
- packets sent to directed broadcast IP addresses, delivered to all
  - hosts on subnet by router
  - all hosts respond to target
- countermeasure
  - routers block directed broadcast from outside

Using compromised hosts
- attacker uses zombie devices
- countermeasure
  - antivirus, patch, update systems

Countermeasures & Famous DDoS Attacks

DDoS Prevention, Detection & Response
- prevention
  - allocate backup resources & modify protocols
  - aim to still be able to provide service when under DDoS
- detection
  - aim to quickly detect & respond
  - look for sus pattern of traffic
- response
  - aim to identify attacker so can apply technical/legal measure
  - cannot prevent current DDoS, but may prevent future

Defending DDoS
- firewall, switches, routers
  - rate limiting
  - add rules

Famous DDoS Attacks
- Trin00
  - U of Minnesota went down 3 days
- Github 1.35 Tbps
- Occupy Central, Hong Kong 500Gbps
- Cloudflare 400 Gbps
- Spamhaus 300 Gbps

Digital Attack Map
- live map which shows attacks right now